

A Low-Cost Hybrid Elliptic Curve Cryptography Authentication Protocol for Trustworthy Internet of Things Communication

Amal Al-Rasheed¹, Rahim Khan², Aftab Ahmad³, Aamir Saeed⁴, Fahad Alturise, and Salem Alkhalaf⁵

Abstract—The Internet of Things (IoT) consists of smart devices equipped with embedded sensors and actuators that interact with their surrounding environment, collect data, and share refined information with nearby server modules for informed decision-making. In most IoT networks, devices communicate over shared channels, making them highly vulnerable to intruder attacks aimed at eavesdropping on or hijacking communication sessions. Consequently, verifying the trustworthiness and legitimacy of both communicating entities—the source and destination devices—is essential before initiating any communication session. Although numerous authentication algorithms have been proposed in the literature to safeguard IoT devices from potential adversaries, existing approaches often suffer from limitations such as application specificity, high complexity, poor scalability, and limited robustness. To address these challenges, this paper introduces a hybrid authentication algorithm in which the source module verifies the trustworthiness of the destination through an encrypted challenge. This challenge is generated using a hybrid mechanism that combines Elliptic Curve Cryptography (ECC) with a pre-shared secret key. A legitimate destination device must successfully resolve the challenge and generate a timely response—an encrypted counter-challenge for the source device. The proposed hybrid authentication model ensures privacy preservation and message integrity for both communicating IoT devices. Its security and resilience against various intruder attacks are validated using OMNET++. Moreover, the model achieves significantly lower resource consumption compared to existing schemes, demonstrating approximately 17%, 21%, and 12% reductions in communication, processing, and storage costs, respectively, as illustrated through both textual and graphical evaluations.

Index Terms—Internet of Things, secure communication, hybrid model, ECC, hash function, authentication.

Received 30 November 2025; revised 9 January 2026; accepted 2 February 2026. Date of publication 6 February 2026; date of current version 2 June 2026. This work was supported in part by Princess Nourah bint Abdulrahman University Researchers Supporting Project under Grant PNURSP2026R235 and in part by Princess Nourah bint Abdulrahman University, Riyadh, Saudi Arabia, under Grant PNURSP2026R235. (Corresponding author: Rahim Khan.)

Amal Al-Rasheed is with the Department of Information Systems, College of Computer and Information Sciences, Princess Nourah bint Abdulrahman University, P.O. Box 84428, Riyadh 11671, Saudi Arabia.

Rahim Khan and Aftab Ahmad are with Abdul Wali Khan University Mardan, Mardan 23200, Pakistan (e-mail: rahimkhan@awkum.edu.pk).

Aamir Saeed is with the Department of Computer Science and IT, UET Peshawar, Jaloza Campus, Nowshera 24110, Pakistan.

Fahad Alturise is with the Department of Cybersecurity, College of Computer, Qassim University, Buraydah 52571, Saudi Arabia.

Salem Alkhalaf is with the Department of Computer Engineering, College of Computer, Qassim University, Buraydah 52571, Saudi Arabia.

Digital Object Identifier 10.1109/TCE.2026.3662053

I. INTRODUCTION

A RAPIDLY evolving technological paradigm called as the Internet of Things (IoT) links physical objects—such as sensors, actuators, automobiles, machinery, appliances, and other embedded systems—to the internet to gather, share, and analyze data autonomously by interacting with the environment directly. These devices sense their surroundings, communicate intelligently by selecting an optimal path, and act on the captured or received information through seamless communication, and make a transformation in the interaction procedures adopted by human beings, systems, devices, and services. In IoT, a device communicates with another device or server through a shared communication medium [1]. As packet transmission is carried out on an unsecured communication channel, it is highly likely that these packets may be intercepted by the intruder devices either to steal valuable information or pretend to be a legitimate/trusted server. In order to make these networks prune against well-known intruder attacks, every device and server must ensure the trustworthiness of another module before initiating an actual communication session. For this purpose, mutual authentication schemes have been introduced in the literature where legitimacy of both parties is thoroughly examined through sophisticated authentication processes [2]. Secondly, this authentication process is required to be completed within the minimum possible timeline and compatible with the evolving networking infrastructure of the IoT.

A decentralized and blockchain-enabled access control mechanism (ReLAC) was introduced by J. Zong and et al. [3] where consumer devices have revocable access rights. However, scalability of the ReLAC is affected for the large scale system as revocation process needs re-generation of keys or re-encryption. Similarly, a distributed fashion-enabled authentication scheme was presented to ensure trustworthiness among communicating devices in the server oriented architecture for the IoT [4]. Additionally, public and private keys are used to make sure that both communicating parties are trusted. Although, it provides the expected level of security, however, the authentication process is overly complex and would become very hard for the large IoT networks. A CUDA-enabled Bidirectional Long Short-Term Memory network is used in the design of a deep learning-based intrusion detection system that is trained to identify several attack types in the IoT [5]. B. Gong et al. [6] have developed a Lightweight

Cross-Domain Mutual Identity Authentication where binary symmetric polynomials are used for key generation that has greatly reduces computational complexity. Likewise, a hybrid of hash function and AES was generated to ensure authenticity of the various devices in the IoT using six messages [7]. However, the authentication process is very lengthy and it involves AES, which is a complex encryption scheme by itself. Similarly, a blockchain-enable device mutual authentication scheme was introduced to make sure that both parties are trusted in the IoT networks [8]. However, blockchain is a complex and lengthy procedure and its applicability in the resource limited networks is questionable. Yin et al. [9] have developed a certificate-less authentication system that uses signatures to provide robust security without requiring a whole certificate infrastructure. To ensure device's identification and session key secrecy, a unique address or interface identifier, that is based on simple cryptographic operations like hash and XOR, is allocated to each device [10]. Scalability and centralized gateway are the main issues associated with this scheme. Similarly, various authentication schemes have been introduced in literature, however, complexity, communication, processing, and memory overheads are among the challenging issues associated with these methodologies. Therefore, a lightweight and generalized verification process is needed to be developed that is applicable to the different networking infrastructures, especially IoT.

In this paper, a hybrid authentication algorithm is presented where verification of the source and destination devices is based on the precise and accurate solution of the encrypted challenge, especially within a defined time interval. Initially, elliptic curve cryptography is used to devise secret key, i.e., λ , for every device and server modules. For safety and security of the system, these keys are generated and shared with the respective modules by the Trusted Authority in an offline phase where entry of the intruder is not possible. The proposed scheme utilizes a symmetric key that is faster than asymmetric key cryptography. Moreover, device and server verify the trustworthiness of the respective module with minimum possible communication and processing overheads, i.e., two messages for mutual authentication. Secondly, the privacy of every device and server is preserved, as it has a separate secret key for the encryption and decryption of messages. Finally, in the proposed setup, a device communicates with another module only if it is deployed within the coverage area of the wireless transceiver. The main scientific contributions of the paper are as given below.

- 1) A hybrid device to server verification algorithm where source and destination modules should resolve the encrypted challenge within the defined time frame.
- 2) Integration of symmetric key cryptography to ensure fast and timely processing of the authentication process on devices and servers.
- 3) A trustworthy autonomous communication infrastructure where legitimate modules, i.e., devices and servers, communicate securely in the presence of adversaries in IoT.

The remaining paper is organized as follows.

The proposed challenge-oriented authentication mechanism is described in detail, such as how a challenge is generated

and how much time it has to wait for the resolved challenge from a legitimate module. In the simulation and results section, performance of the proposed challenge-oriented algorithm is evaluated and compared with the available algorithms. Finally, concluding remarks are given.

II. PROPOSED CHALLENGE-ORIENTED AUTHENTICATION ALGORITHM FOR IOT

We have employed ECC, hash function, and symmetric key, i.e., λ_i , cryptography to ensure mutual authentication among interested devices, i.e., D-to-D or D-to-S or S-to-S, in IoT. In this approach, every object, i.e., a device or server, gets an elliptic curve cryptography-based secret key certificate to encrypt messages transmitted through an insecure communication medium. If a device requires to communicate with another device or server module, it verifies the trustworthiness of the device or server. Initially, every object should be part of the activities carried out in the offline phase, where every object gets registered. Secondly, the registration process is performed offline to ensure the registration of legitimate modules only. Thirdly, every device or server module should have a secret key certificate (SKC) issued by the respective certificate authority (CA). In the offline registration phase, these objects send SKC and media access control (MAC) to the centralized server or edge module. This process is repeated for every trusted device and server module in the IoT. Thus, every device or server has a secret key certificate of trusted modules in the IoT. As soon as this process is completed, authentication of both the device and server modules is performed using minimum possible messages. In proposed mutual authentication, the source device or server module sends a requesting challenge that is converted into plain text via the secret key λ_i . The destination module, i.e., device or server, converts it to plain text via the secret key λ_j . A response message is generated and encrypted with its elliptic curve-enabled secret key λ , which is convertible into equivalent plain text only if and only if the destination module has its secret key. As the source device is a trusted party, surely it will have the required secret key λ for the decryption of message. Thus, mutual authentication of both modules is verified using minimum possible messages, i.e., two in this case. In scenarios where the trustworthiness of either the source or destination object, i.e., device or server, is questionable, then the request for the communication session is terminated. Moreover, in the proposed mutual authentication scheme, every object, i.e., trusted or intruder, has been provided with a maximum of three attempts. If an object doesn't provide credentials in three consecutive encrypted messages, then it is assumed as malicious or intruder, and it's rejected. The proposed elliptic curve and secret key-enabled mutual authentication process are broadly divided into the following phases.

- 1) Offline or Registration Phase (Every object is registered with Trusted Authority and gets a secret keys list, i.e., λ_i)
- 2) Log in Phase (Every object logs in using its secret credentials)
- 3) Authentication Phase (Verifies Trustworthiness of another object, i.e., device or server module)

A. Offline Registration Phase

In the proposed scheme, every object, i.e., device or server, should be registered with the TA in the offline phase to prohibit adversary modules' entry. Moreover, the MAC address of every trusted module, i.e., device or server, is assumed to be registered with the TA. Similarly, the MAC address of the TA is shared with the trusted objects in IoT. Initially, a device interested in registration chooses λ_i as its secret key such that $[1 < \lambda_i < n \ \& \ \lambda_i \in \mathbb{Z}_q^*]$ and then session key β_i using equation. 1.

$$\beta_i = \lambda_i * P \quad (1)$$

λ is the secret key, and P is the respective elliptic curve point. The secret key β_i is shared with CA to get the elliptic curve-enabled secret key certificate. Similarly, every server chooses a pair of keys, i.e., λ_j and β_j as secret keys such that $[1 < \beta_j < n \ \& \ \lambda_j \in \mathbb{Z}_q^*]$ where β_j selection is based on Equation. 2.

$$\beta_j = \lambda_j * P \quad (2)$$

Moreover, secret keys of the respective server modules are shared with the trusted devices and vice versa. Similarly, the secret keys of every registered device are shared with another in the form of a list used for authentication. The whole registration process of modules with the respective TA is given below. If $X \rightarrow Y : M$ represents a message M generated by X and sent to Y .

Step-I Every device V_i chooses a random number R_1 such that $R_1 \in \mathbb{Z}_q^*$. Furthermore, it computes $R_D = R_1 \cdot \beta_j$ and contribution value k , which is based on the Elliptic curve Diffie-Hellman (ECDH) as given in Equation. 3.

$$K = R_1 \cdot \lambda_j \cdot \beta_j \cdot P = (KX, KY) \quad (3)$$

The updates related to the symmetric session key are performed using KX . Every device must select a random number, such as $R_1 \in \mathbb{Z}_q^*$, before updating its ECDH-based symmetric session key. This random number is integrated with the MAC address MAC_v and encrypted with KX as given in the equation. 4.

1) *Device or Server to Trusted Authority:*

$$Msg - I = E_{KX}(MAC_v || R_1 || R_D) \quad (4)$$

Step-II Trusted authority receives a registration request message from an object, i.e., device or server. Initially, TA retrieves the MAC address of the source module, i.e., MAC_v , from $Msg-I$, secret key β_i , and computes ECDH based symmetric key k as given in equation. 5.

$$K = \beta_i \cdot R_1 = \beta_i \cdot R_1 \cdot \lambda_i \cdot P = (KX, KY) \quad (5)$$

KX is used by TA to convert the encrypted message into equivalent plain text to retrieve R_1, MAC_v , and R_D . Furthermore, trustworthiness of the source module is carried out through a sophisticated comparison process where computed MAC_v is matched against the retrieved one. If both match, then the registration process is continued, otherwise terminated immediately. In the farmer's case, TA generates a random number, R_S such that $R_S \in \mathbb{Z}_q^*$ and concatenates R_D with the calculated $R_S = R_S \cdot P$. This message is

encrypted using KX and sent to the respective source module, i.e., device in this case. The message contents are given in Equation. 6

2) *Trusted Authority to Device or Server:*

$$Msg - II = E_{KX}(MAC_{TA} || R_S || R_D) \quad (6)$$

Step-III In this step, every device or server must ensure the authenticity of the TA by matching the retrieved MAC address MAC_{TA} with the stored one. If the addresses match, then the respondent is a trusted device and the registration process continues. Secondly, the device or server converts the encrypted message into plain text using KX and retrieves the random number R_D . It verifies if the received $R_D =$ sent R_D . If yes, then a random password PW_D and produces an HD hash digest of the two factors (MAC_v, PW_D) as $HD = \text{hash}(MAC_D || PW_D)$. Additionally, it generates another H_D that is $H_D = \text{hash}(H_D || R_D || R_S)$ and encrypts it using KX . H_D and R_D are stored in memory of devices or server modules and send an encrypted message as given below in equation. 7.

3) *Device or Server to Trusted Authority:*

$$Msg - III = E_{KX}(R_D || R_S || H_D) \quad (7)$$

Step-IV TA verifies that received $MAC_D =$ communicated MAC_D by converting the encrypted message into plain text. If the above equality holds, then the registration process is continued, otherwise, terminated. Furthermore, TA computes R_D and H_D . If the retrieved values are similar to the stored ones, then the registration process is successful. TA stores MAC_v , H_D , and R_D for onward communications.

B. Login Phase

After completion of the registration phase, a device can communicate with the respective server module, which is subjected to its successful login with the nearest server module. For this purpose, the secret credentials of every device and server, such as MAC address and password, are used in the following ways.

Step-1: *device $\rightarrow$ server*

A login request with the device's MAC address and the encrypted hash digest HD as $H_D = h(MAC_D || PW_D)$ and random number R_D is sent from the device to the respective server module. These credentials are encrypted through KX to ensure their integrity and trustworthiness during the transmission process over a shared communication medium. $E_{KX}(MAC_D || H_D || R_D)$

Step-2: *server $\rightarrow$ device*

The login request is received at the concerned server module, and it extracts the source modules' identity from the cipher text message. Furthermore, the MAC address of the requesting module is passed through a rigorous inspection process where its accuracy and integrity are checked by comparing the computing hash of the MAC with the received one. If both hashes are the same, then KX is used to convert the encrypted message into plain text to get H_D and R_D values of the requesting device. Additionally, the server module compares the received H_D & R_D with the stored one. If these values are

accurate, the requesting device is trusted and the server will grant permission to start communication. In case of failure, the login request is terminated, and a potential threat is circulated among trusted devices in the IoTs. Finally, a trusted device is allowed to make a maximum of three attempts. If it fails, then it is treated as an adversary and added to the blocked devices.

C. Mutual Authentication Phase

After a successful login, mutual authentication is required to start communication between device and server modules in the IoT. In this phase, both parties, i.e., source and destination, must confirm the authenticity of the other module and generate a secret session key. The description of the mutual authentication phase is as follows: $X \rightarrow Y : M$ where M represents a message that source device X is interested in sending to the destination Y .

Step-1:

1) *Device* $\rightarrow$ *Server*: $MAC_D, E_{KX}(R_D || H_D)$ The device sends its MAC address MAC_D along with encrypted random point R_D and hash digest H_D as $H_D = h(MAC_D || PW_D)$ using KX as an encryption key.

Step-2:

2) *Server* $\rightarrow$ *Device*: $MAC_S, E_{KX}(MAC_S || R_D || R_S)$ The respective server module receives the authentication request from the interested device. Initially, it checks the received MAC_D with the stored one, and if not matched, the authentication request is rejected. Otherwise, the encrypted challenge is resolved through KX to get H_D and R_D , which are compared with the stored one. If both are matched, the respective server continues the authentication process and generates an encrypted response using KX , as given below.

$$E_{KX}(MAC_S || R_S || R_D)$$

Step-3:

The requesting device converts the encrypted message into plain text using KX and compares the received MAC_S with the stored one. In scenarios where a match is encountered, it further checks R_D and R_S values. If matched, the respective server module is trusted, and it verifies the trustworthiness of the server module to the requesting device. Thus, both parties have confirmed mutual authenticity and can start a proper communication session.

Therefore, authentication schemes should be pruned against both attacks. A strong encryption mechanism should be adopted to convert plain text into equivalent cipher text. However, the authenticity of the requested module should be checked before initiating actual communication sessions. Therefore, both the device and the server are trusted. This process is carried out before actual data is transferred. Thus, if a device, i.e., source or destination, has the expected security level, i.e., the device on the other side is trusted, then it can trigger the communication process; otherwise, abort it. For this purpose, a simplified authentication scheme is presented in this section where only trusted devices are allowed to communicate.

The above-mentioned mutual authentication methodologies are presented in the form of algorithms, i.e., Algorithm-1: Requesting device and Algorithm-2: Respective server Module in the IoT.

Algorithm 1 Authentication Request Generation and Verification: Device Side

Require: Verification of the Respective server module.
Ensure: Trusted server

- 1: V_i verified devices in IoT
- 2: R_j verified servers or Servers in IoT
- 3: $MAC_R \leftarrow$ MAC addresses of R_j
- 4: H_S hash digest of server R_j
- 5: R_S Random number
- 6: **for** (Every Message msg_j from R_j)
- 7: **if** ($MAC_S[msg_j] \in MAC_S[R]$) **then**
- 8: $KX(MAC_S || H_S || R_S)$
- 9: **if** ($H_S[msg_j] \in H_S[Stored] \& (R_S[msg_j] \in R_S[Stored])$) **then**
- 10: R_j is Verified
- 11: $E_{KX}(MAC_D || H_D || R_D)$
- 12: **else then**
- 13: server or device is a Potential Intruder
- 14: Block MAC_j
- 15: Shares MAC_j with other devices
- 16: **endif**
- 17: **endifor**
- 18: **return** Trusted Module R_j

III. MATHEMATICAL MODELING OF THE HYBRID AUTHENTICATION SCHEME

A compact mathematical model that captures the hybrid (ECC $\rightarrow$ symmetric) two-message mutual-authentication scheme with per-device privacy and radio-coverage constraints is given below.

A. Entities and Sets

Let $\mathcal{V} = \{V_i\}$ be devices, $\mathcal{R} = \{R_j\}$ be servers, and TA the trusted authority. Each module $X \in \mathcal{V} \cup \mathcal{R}$ has an identity ID_X and a long-term secret λ_X (derived via ECC). Time is slotted: $t \in \mathbb{N}$. Locations are points in $\mathbb{R}^2$ (or $\mathbb{R}^3$) with position $x_X(t)$.

IV. ENTITIES & SYMBOL DEFINITIONS

A. ECC Setup (Offline, Hybrid Root of Trust)

Let $(\mathbb{F}_q, E/\mathbb{F}_q, G)$ be an elliptic-curve group of prime order n with generator G . The TA samples a secret $s \in \mathbb{Z}_n$ and publishes (E, G) . For each module X , the TA computes a per-module ECC secret

$$\lambda_X \leftarrow H_1(ID_X || s) \in \mathbb{Z}_n, \quad (8)$$

optionally sets a public point $P_X = \lambda_X G$, and installs λ_X into X via an offline, intrusion-free process.

B. Pairwise Symmetric Roots

For any pair (V_i, R_j) , define a static pairwise symmetric root key

$$k_{ij}^* = \text{KDF}(\lambda_{V_i} || \lambda_{R_j}) \quad (9)$$

(where $\text{KDF} : \{0, 1\}^* \rightarrow \{0, 1\}^\ell$ is a key-derivation function with security level ℓ bits). This enables fast symmetric cryptography online while the ECC layer anchors trust to the TA.

Algorithm 2 Authentic Response Generation and Verification: Server Side

Require: Verification of the Requesting device V_i .
Ensure: Trusted or Intruder

- 1: V_i verified devices in IoT
- 2: R_j verified servers or Servers in IoT
- 3: $MAC_R \leftarrow$ MAC addresses of V_i
- 4: H_D hash digest of device V_i
- 5: R_D Random number
- 6: **for** (Every Message msg_i from V_i)
- 7: **if** ($MAC_D[msg_i] \in MAC_D[MAC_R]$) **then**
- 8: $KX(MAC_D S || H_D || R_D)$
- 9: **if** ($H_D[msg_i] \in H_D[Stored] \& (R_D[msg_i]) \in R_D[Stored]$) **then**
- 10: V_i is Verified
- 11: $E_{KX}(MAC_S || R_S || R_D)$
- 12: **else then**
- 13: device is a Potential Intruder
- 14: Block MAC_D
- 15: Shares MAC_D with other Servers or servers
- 16: **endif**
- 17: **endfor**
- 18: **return** Trusted Module V_i

C. Coverage Constraint (Wireless Feasibility)

Let $R > 0$ be the transceiver coverage radius. Communication between V_i and R_j at time t is feasible iff

$$\text{cov}_{ij}(t) = \mathbf{1}\{ \|x_{V_i}(t) - x_{R_j}(t)\|_2 \leq R \}. \quad (10)$$

All online protocol steps below are conditioned on $\text{cov}_{ij}(t) = 1$.

D. Privacy via Pseudonyms

Each device publishes an unlinkable pseudonym

$$\text{PID}_{V_i,t} = H_2(\lambda_{V_i} || t), \quad (11)$$

rotated with time (or epoch) t . servers use a stable identifier ID_{R_j} or a pseudonym $\text{PID}_{R_j,t}$ analogously.

E. Online Two-Message Mutual Authentication

Let Enc/Dec be an IND-CPA secure symmetric cipher and MAC a SUF-CMA secure message authenticator. To minimize overhead, the protocol uses exactly two messages and derives an ephemeral session key.

F. Message 1 (Device $\rightarrow$ Server)

device V_i samples a nonce $N_i\{0, 1\}^\ell$ and computes

$$k_{ij}^* = \text{KDF}(\lambda_{V_i} || \lambda_{R_j}), \quad (12)$$

$$C_1 = \text{Enc}_{k_{ij}^*}(\text{PID}_{V_i,t} || N_i || t), \quad (13)$$

$$\mu_1 = \text{MAC}_{k_{ij}^*}(\text{PID}_{V_i,t} || N_i || t). \quad (14)$$

It sends

$$M_1 = \langle \text{PID}_{V_i,t}, C_1, \mu_1 \rangle. \quad (15)$$

G. Server Processing

Upon receiving M_1 , R_j recomputes k_{ij}^* , verifies μ_1 and decrypts C_1 . If valid, it samples a nonce $N_j\{0, 1\}^\ell$ and derives the ephemeral session key

$$K_{ij,t} = \text{KDF}(k_{ij}^* || N_i || N_j || t). \quad (16)$$

H. Message 2 (Server $\rightarrow$ Device)

The server returns evidence of freshness and liveness:

$$\sigma_2 = \text{MAC}_{k_{ij}^*}(\text{PID}_{V_i,t} || N_i || N_j || t), \quad (17)$$

$$C_2 = \text{Enc}_{k_{ij}^*}(N_j || t), \quad (18)$$

$$M_2 = \langle \text{ID}_{R_j} \text{ or } \text{PID}_{R_j,t}, C_2, \sigma_2 \rangle. \quad (19)$$

V_i verifies σ_2 , decrypts C_2 , and computes the same $K_{ij,t}$.

I. Correctness

If both parties follow the protocol and $\text{cov}_{ij}(t) = 1$, then

$$\Pr[K_{ij,t}^{(V)} = K_{ij,t}^{(R)}] = 1. \quad (20)$$

J. Security Goals (Sketch)

Let $\mathcal{A}$ be a PPT adversary controlling the channel.

- **Mutual Authentication.** Under SUF-CMA security of MAC and secrecy of k_{ij}^* , $\text{Adv}_{\mathcal{A}}^{\text{auth}} \leq \text{Adv}_{\mathcal{A}}^{\text{mac-forgery}} + \text{negl}(\ell)$. Any successful impersonation requires forging μ_1 or σ_2 .
- **Key Secrecy.** If Enc is IND-CPA and KDF is a PRF-based extractor, session keys $K_{ij,t}$ are indistinguishable from random: $\text{Adv}_{\mathcal{A}}^{\text{key-ind}} \leq \text{Adv}_{\mathcal{A}}^{\text{prf}} + \text{Adv}_{\mathcal{A}}^{\text{ind-cpa}} + \text{negl}(\ell)$.
- **Privacy/Unlinkability.** If H_2 is a random oracle/PRF and t (or salt) evolves, then for any two devices $V_i, V_{i'}$, $\text{PID}_{V_i,t} \approx \text{PID}_{V_{i'},t}$ from the adversary's view; linking advantage is negligible without access to λ_{V_i} .

K. Minimal Overheads

Communication: exactly two messages:

$$\begin{aligned} \text{comm_bits} &= |M_1| + |M_2| = |\text{PID}| + |C_1| \\ &\quad + |\mu_1| + |\text{ID}/\text{PID}_R| + |C_2| + |\sigma_2|. \end{aligned} \quad (21)$$

Computation (online): each side performs

$$\begin{aligned} \text{cost}_{\text{veh}} &= 1 \text{ KDF} + 1 \text{ Enc} + 1 \text{ MAC}, \quad \text{cost}_{\text{server}} \\ &= 1 \text{ KDF} + 1 \text{ Dec} + 2 \text{ MAC} + 1 \text{ Enc}. \end{aligned} \quad (22)$$

All ECC operations are confined to the offline phase (deriving λ_X), hence the online path uses only symmetric primitives.

L. Access Control by Coverage

Let $\text{Auth}_{ij}(t)$ denote the event that both verifications succeed. Effective communication is allowed iff

$$\text{Allow}_{ij}(t) = \text{cov}_{ij}(t) \wedge \text{Auth}_{ij}(t). \quad (23)$$

TABLE I
ENTITIES AND SYMBOL DEFINITIONS USED
IN THE MATHEMATICAL MODEL

Symbol	Meaning / Definition
$\mathcal{V} = \{V_i\}$	Set of devices.
$\mathcal{R} = \{R_j\}$	Servers.
TA	Trusted Authority.
ID_X	Permanent identifier of entity $X \in \mathcal{V} \cup \mathcal{R}$.
$PID_{X,t}$	Pseudonym (ephemeral identifier) of X at epoch t .
λ_X	Per-entity long-term secret (ECC-derived) for X .
s	TA master secret (ECC scalar).
$(E, \mathbb{F}_q, G, n)$	Elliptic curve group parameters with generator G and order n .
KDF	Key derivation function (e.g., HKDF).
H	Hash function (e.g., SHA-256).
Enc, Dec	Symmetric encryption/decryption algorithms (IND-CPA).
MAC	Message authentication code (SUF-CMA).
k_{ij}^*	Pairwise symmetric root key between V_i and R_j .
N_i, N_j	Nonces sampled by V_i and R_j , respectively.
$K_{ij,t}$	Ephemeral session key for pair (V_i, R_j) at epoch t .
ℓ	Security parameter / key length (in bits).
$\mathbf{x}_X(t)$	Position vector of entity X at time t (in $\mathbb{R}^2$ or $\mathbb{R}^3$).
R_{cov}	Wireless transceiver coverage radius.
$cov_{ij}(t)$	Coverage indicator between V_i and R_j at time t (0/1).
$Auth_{ij}(t)$	Event that mutual authentication between V_i and R_j at t succeeds.
$Allow_{ij}(t)$	Event that communication is allowed (coverage & auth).
$\mathcal{A}$	Probabilistic polynomial-time adversary controlling the channel.

M. Threat Model

The adversary can eavesdrop, replay, drop, and inject messages, but cannot compromise the offline phase (no intruder device entry). Compromise of a single λ_{V_i} endangers only keys derived with that device; other pairs remain secure due to per-entity secrets.

N. Optional: TA-Assisted Rekey

Periodic refresh can be modeled by

$$k_{ij}^{*(u+1)} = \text{KDF}(k_{ij}^{*(u)} \parallel H_3(u)), \quad (24)$$

or by rotating pseudonyms via epoch $t \leftarrow t + 1$.

Instantiation Notes: Typical choices: Enc = AES-GCM, MAC from GCM tag or HMAC; KDF via HKDF; $H_{1,2,3}$ via SHA-256. Security parameter $\ell \in \{128, 192, 256\}$.

V. PERFORMANCE EVALUATION

To verify the claims of the proposed hybrid challenge-enabled mutual authentication scheme, it is implemented in OMNET++. In the simulation setup, a device can communicate with another device or server module where both parties use credentials to verify the trustworthiness of another party. Furthermore, every device and server in the proposed infrastructure was static consistent with the realistic environment of the IoT. Secondly, an intruder module could be a device or server. Therefore, vulnerabilities of the proposed mutual authentication approach were thoroughly examined and tested in both scenarios, i.e., (i) situations where the device is a potential adversary module and (ii) scenarios where an intruder device pretends to be a legitimate server module. The coverage

TABLE II
PARAMETERS FOR THE PROPOSED INTERNET
OF DEVICE INFRASTRUCTURE

Parameter Name	Approximate Values
Coverage Area	1500 x 1500
Simulation Software	OMNET++
Active devices	100 to 1000
Server	5% (one per hundred devices)
Trusted Module (TA)	One
Sampling Interval of device	15 μ Sec
Bandwidth of the Channel or Link	10 Mbps
Energy for Packet Transmission	75.6 mW
Energy for Packet Receiving	75.6 mW
Coverage area of XBEE module	500 to 800 Meters
Packet Size	128 Kbps
Hand-off Time	10 nano Sec
device Speed (Max)	160 km/hour
Transmission interval	Application Oriented
Adversary A_k	Randomly Generated

TABLE III
REFERENCE VALUES FOR THE PROCESSING TIME
COMPUTATIONAL OVERHEAD

Notations	Approximate Execution Time	Time (ms)
T_{ECM}	Scalar Multiplication of ECC	17.1
T_C	Chaotic Map (Chebyshev) Operation	0.32
$T_{SE/D}$	Encryption/Decryption (Symmetric)	5.6
T_H	Hash Function (one way SHA-1)	0.32
T_{fe}	Fuzzy Extraction Operation	17.1

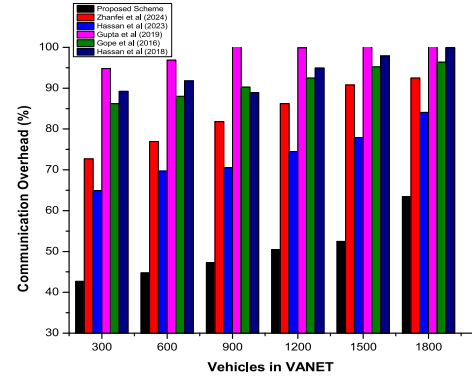


Fig. 1. Processing requirements of existing and proposed algorithms.

area of the devices' transceiver module, represented as T_p and used for the packet transmission, of every device was approximately 500 and 800 meters in direct line of sight and obstetrical-enabled areas, respectively. Likewise, every device is assumed to have a state-of-the-art smart sensing-enabled detection and control mechanism that avoids accidents and other related scenarios where applicable. The proposed mutual authentication scheme was evaluated through different performance indicators, such as communication, processing, and storage overheads. Various parameters used in the proposed mutual authentication setup are shown in the table. II.

Furthermore, time requirements for various operations, i.e., notations used in the proposed and existing approaches, are based on the following approximate values in Table. III

TABLE IV
COMPARATIVE ANALYSIS OF THE COMMUNICATION COST

Scheme	Number of Messages	User	device or IoT Node	Gateway or server	Total
Proposed Scheme	4	—	512	512	1024
Poorambage et al. [11]	4	768	768	1824	3360
Turkanovic et al. [12]	4	672	576	1472	2720
Dhillon and Karla [13]	4	992	512	1024	2528
Cheng and Le [14]	4	672	512	1088	2272
Jiang et al. [15]	4	512	1056	384	1952
Shuai et al. [16]	4	864	544	960	2368
Wazid et al. [17]	4	736	512	1344	2592
Sadhukhan et al. [18]	4	320	768	512	1600
Fakroon et al. [19]	4	800	416	1088	2304

TABLE V
COMPARISON IN TERMS OF ALGORITHM'S COMPUTATIONAL COST

Scheme	User/Client	Device C_i	Server Side S_j
Proposed scheme	—	$2T_H + 2T_{SE/D}$	$2T_H + 2T_{SE/D}$
Challa et al. [17]	$1T_{fe} + 5T_H + 5T_{SE/D}$	$3T_H + 4T_{ECM}$	$4T_H + 5T_{ECM}$
Turkanovic et al. [12]	$7T_H$	$7T_H$	$5T_H$
Poorambage et al. [11]	$8T_H + 4T_{ECM}$	$10T_H + 11T_{ECM}$	$5T_H + 8T_{ECM}$
Dhillon and Karla [13]	$8T_H$	$6T_H$	$8T_H$
Cheng and Le [14]	$9T_H + 2T_{ECM}$	$5T_H + 2T_{ECM}$	$7T_H$
Shuai et al. [16]	$6T_H + 1T_{ECM}$	$3T_H + 1T_{ECM}$	$7T_H + 1T_{ECM}$
Jiang et al. [15]	$7T_H$	$5T_H$	$10T_H$
Wazid et al. [17]	$1T_{fe} + 13T_H + 2T_{SE/D}$	$4T_H + 2T_{SE/D}$	$5T_H + 4T_{SE/D}$
Sadhukhan et al. [18]	$2T_H + 1T_{ECM} + 2T_{SE/D}$	$1T_H + 1T_{ECM} + 2T_{SE/D}$	$2T_H + 4T_{SE/D}$

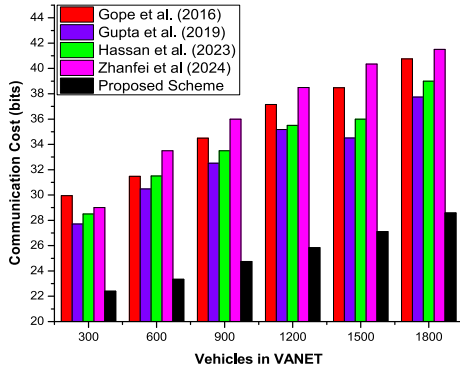


Fig. 2. Communication requirements of existing and proposed algorithms.

A. Approximate Processing Overhead: Comparison

Processing cost overhead is the approximate time required for the mutual authentication of both parties, i.e., source (device or server) and destination module. It is computed when the source module (i.e., a device) initializes the respective authentication process by generating an encrypted message through its secret key that is shared in the offline phase if needed and sends it to the respective destination module, i.e., the nearest server. The successful delivery of this encrypted message enables the destination module to verify the trustworthiness of the source module through its secret key or hash function. If trustworthiness is proved, it generates a response challenge converted into cipher text with a secret key and a certain portion of the original message, preferably in encrypted form, and sent back to the concerned source module, i.e., device. The authentication process is complete if the source module finds that the module on the other side is

trustworthy. The proposed scheme and state-of-the-art approaches were compared for the processing time overhead, as shown in Table. IV. These costs were computed in OMNET++ while keeping the IoT infrastructure and its parameters consistent for the proposed and existing algorithms. The proposed approach has outperformed other algorithms by completing the mutual authentication process with the minimum possible processing cost overhead in the IoT. Secondly, these measures were computed in the presence of various adversary modules, which were continuously trying to break the cipher using different attacks. Additionally, the processing time of these algorithms is shown in Figure. 1.

B. Approximate Communication Overhead: Comparison

In mutual authentication processes, an algorithm is assumed to be perfect, especially from the communication overhead perspective, if it needs to transmit a minimum number of bits to complete the authentication process while maintaining its protection against well-known intruder attacks. In the proposed authentication approach, two messages, i.e., (i) Source module (device or server) generated challenge and (ii) destination module updated challenge, are required to be transmitted in encrypted form to confirm the trustworthiness of both objects. As in the proposed approach, every message consists of 128 bits; therefore, a total of 264 bits are required to be transmitted in the authentication process of the legitimate modules in IoT. It is important to note that existing algorithms have a four-tier, i.e., minimum of four messages, methodology to verify the legitimacy of both parties in IoT. Moreover, the proposed approach has an offline phase, where messages are transmitted. However, those messages are sent only once, preferably before activating the IoT in the realistic

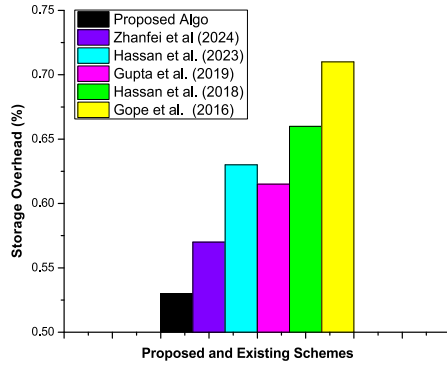


Fig. 3. Storage requirements of existing and proposed algorithms.

TABLE VI
COMPARATIVE ANALYSIS OF THE COMMUNICATION COST

Scheme	Server Storage Cost	Device Storage Cost
Proposed Scheme	320	320
Turkanovic et al. [12]	768	512
Dhillon and Karla [13]	640	512
Das et al. [20]	$768 + CH^*$	-
Wazid et al. [17]	576	512
Sadhukhan et al. [18]	480	356
Fakroon et al. [19]	704	1056

environment. A thorough and comparative analysis of the proposed and existing algorithms is presented in Table. V. These results have verified the outclass performance of the proposed authentication scheme against available state of the art. These values were obtained in active IoT where intruder modules try to breach the networks via various crypt-analysis approaches and attacks. Additionally, the communication cost of these algorithms is shown in Figure. 2.

C. Approximate Storage Overhead: Comparison

In smart application environments such as smart cities, smart hospitals, and smart homes, storage cost overhead is very crucial and required to be utilized effectively, especially if an object, i.e., device or server, have to rely on its internal storage only. Secondly, permanent storage requirement should be kept at minimum possible threshold to make sure that enough storage space is available for the completion of various activities in IoT. In symmetric key-enabled algorithm, a device or server has to keep the secret key along with other important metrics in the memory to ensure verification process, i.e., trustworthiness, of the requesting modules. The proposed mutual authentication approach stores in memory the secret key, i.e., λ_i , other metric required for the verification process in the active IoT. A thorough and detailed analysis of the proposed mutual authentication and field-proven algorithms is shown Table. VI where it is confirmed that the proposed scheme has efficiently utilized the available storage space. Additionally, storage requirement of these algorithms are shown in Figure. 3.

VI. CONCLUSION

Technological advancements have let to the development of a collaborative network where devices, pedestrians, and servers

operate smartly by sharing information on the need based fashion. To safeguard against well-known intruder attacks, every module, i.e., device or server, uses encryption (symmetric or asymmetric) to preserve integrity and confidentiality of the shared data. Generally, a shared communication channels were used for the packet transmission, which makes the IoT communication session highly susceptible to various intruder attacks. Therefore, an encrypted challenge-oriented methodology, i.e., source generates and destination resolve it, were presented to secure every communication activity against potential adversaries searching for an opportunity to attacks. In literature, various authentication algorithms were developed to safeguard IoT against those attacks, but these approaches have certain limitations. In this paper, a hybrid mutual authentication algorithm was developed to make sure that both parties, i.e., source and destination interested in sharing of information, were trustworthy. In this approach, every module used ECC to generate λ that was shared with the trusted authority (TA) to complete the registration process. In the authentication phase, different encrypted challenges were sufficient to confirm trustworthiness of devices and servers. The proposed hybrid authentication approach had the potentials to preserve integrity of messages transmitted via the open channels, privacy of the source & destination modules, and confidentiality of data. The proposed scheme was simulated in Simulation of Urban Mobility to verify that it was safe against various intruder attacks. Secondly, a comparative analysis of the it with the well-known existing cryptography schemes, particularly in terms of storage, communication, and processing cost overhead, was carried out. The proposed approach had performance is better than existing methodologies as proved by the simulation results. Finally, the proposed authentication algorithm had secured communication sessions against well-known intruder attacks in IoT. The proposed scheme could be extended to scenrios where both devices and server modules are mobile. Currently, it is applicable only to the static devices in the IoT.

REFERENCES

- [1] X. Zang, Z. Zheng, H. Zheng, X. Liu, M. K. Khan, and W. Jiang, "HyperEye: A lightweight features fusion model for unknown encrypted malware traffic detection," *IEEE Trans. Consum. Electron.*, vol. 71, no. 2, pp. 5079–5089, May 2025.
- [2] K. Lv, S. Huang, Y. Yao, W. Jiang, and Z. Feng, "Large language model-empowered energy-efficient multi-UAV-assisted MEC heterogeneous networks," *IEEE Trans. Cognit. Commun. Netw.*, vol. 12, pp. 5281–5294, 2026.
- [3] J. Zong, C. Wang, J. Shen, C. Su, and W. Wang, "ReLAC: Revocable and lightweight access control with blockchain for smart consumer electronics," *IEEE Trans. Consum. Electron.*, vol. 70, no. 1, pp. 3994–4004, Feb. 2024.
- [4] M. Nawaz Khan, H. Ur Rahman, T. Hussain, B. Yang, and S. Mian Qaisar, "Enabling trust in automotive IoT: Lightweight mutual authentication scheme for electronic connected devices in Internet of Things," *IEEE Trans. Consum. Electron.*, vol. 70, no. 3, pp. 5065–5078, Aug. 2024.
- [5] D. Javeed, M. S. Saeed, I. Ahmad, P. Kumar, A. Jolfaei, and M. Tahir, "An intelligent intrusion detection system for smart consumer electronics network," *IEEE Trans. Consum. Electron.*, vol. 69, no. 4, pp. 906–913, Apr. 2023.
- [6] B. Gong, G. Zheng, M. Waqas, S. Tu, and S. Chen, "LCDMA: Lightweight cross-domain mutual identity authentication scheme for Internet of Things," *IEEE Internet Things J.*, vol. 10, no. 14, pp. 12590–12602, Jul. 2023.

- [7] I. Alshawish and A. Al-Haj, "An efficient mutual authentication scheme for IoT systems," *J. Supercomput.*, vol. 78, no. 14, pp. 16056–16087, Sep. 2022.
- [8] S. Qiu, J. Li, X. Di, X. Li, Y. Wu, and M. Ibrahim, "Lightweight mutual authentication scheme based on blockchain for Internet of Medical Things," *IEEE Internet Things J.*, vol. 12, no. 7, pp. 8848–8861, Apr. 2025.
- [9] D. Yin and B. Gong, "A lightweight certificateless mutual authentication scheme based on signatures for IIoT," *IEEE Internet Things J.*, vol. 11, no. 16, pp. 26852–26865, Aug. 2024.
- [10] N. Sharma and P. Dhiman, "A secure addressing mutual authentication scheme for smart IoT home network," *Multimedia Tools Appl.*, vol. 84, no. 22, pp. 25111–25143, Aug. 2024.
- [11] P. Porambage, C. Schmitt, P. Kumar, A. Gurtov, and M. Ylianttila, "Two-phase authentication protocol for wireless sensor networks in distributed IoT applications," in *Proc. IEEE Wireless Commun. Netw. Conf. (WCNC)*, Apr. 2014, pp. 2728–2733.
- [12] M. Turkanović, B. Brumen, and M. Hölbl, "A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion," *Ad Hoc Netw.*, vol. 20, pp. 96–112, Sep. 2014.
- [13] P. K. Dhillon and S. Kalra, "A lightweight biometrics based remote user authentication scheme for IoT services," *J. Inf. Secur. Appl.*, vol. 34, pp. 255–270, Jun. 2017.
- [14] C. Wang, R. Huang, J. Shen, J. Liu, P. Vijayakumar, and N. Kumar, "A novel lightweight authentication protocol for emergency vehicle avoidance in VANETs," *IEEE Internet Things J.*, vol. 8, no. 18, pp. 14248–14257, Sep. 2021.
- [15] D. Wen, X. Li, Y. Zhou, Y. Shi, S. Wu, and C. Jiang, "Integrated sensing-communication-computation for edge artificial intelligence," *IEEE Internet Things Mag.*, vol. 7, no. 4, pp. 14–20, Jul. 2024.
- [16] Q. Jiang, F. Wei, S. Fu, J. Ma, G. Li, and A. Alelaiwi, "Robust extended chaotic maps-based three-factor authentication scheme preserving biometric template privacy," *Nonlinear Dyn.*, vol. 83, no. 4, pp. 2085–2101, Mar. 2016.
- [17] S. Challa et al., "Secure signature-based authenticated key establishment scheme for future IoT applications," *IEEE Access*, vol. 5, pp. 3028–3043, 2017.
- [18] D. Sadhukhan, S. Ray, G. P. Biswas, M. K. Khan, and M. Dasgupta, "A lightweight remote user authentication scheme for IoT communication using elliptic curve cryptography," *J. Supercomput.*, vol. 77, no. 2, pp. 1114–1151, Feb. 2021.
- [19] M. Fakroon, M. Alshahrani, F. Gebali, and I. Traore, "Secure remote anonymous user authentication scheme for smart home environment," *Internet Things*, vol. 9, Mar. 2020, Art. no. 100158.
- [20] A. K. Das and A. Goswami, "A robust anonymous biometric-based remote user authentication scheme using smart cards," *J. King Saud Univ.-Comput. Inf. Sci.*, vol. 27, no. 2, pp. 193–210, Apr. 2015.